

Презентация по выполнению индивидуального проекта №5

Основы информационной безопасности

Дауд Амжад

2026-05-16

1. Информация

Раздел 1

1. Информация

1.1 Докладчик

Дауд Амжад

студентка

Российский университет дружбы народов им. П. Лумумбы

1032245416@rudn.ru

<https://amjaddawud.github.io/ru/>

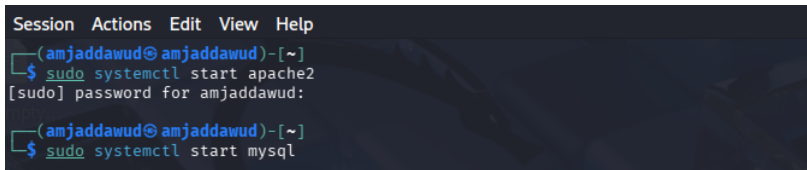


1.2 Цель

Научиться использовать Burp Suite.

1.3 Выполнение лабораторной работы

Запускаю локальный сервер, на котором открою веб-приложение DVWA для тестирования инструмента Burp Suite



```
Session Actions Edit View Help
(amjaddawud@amjaddawud)-[~]
$ sudo systemctl start apache2
[sudo] password for amjaddawud:
(amjaddawud@amjaddawud)-[~]
$ sudo systemctl start mysql
```

Рисунок 1: Запуск локального сервера

1.4 Выполнение лабораторной работы

Запускаю инструмент Burp Suite

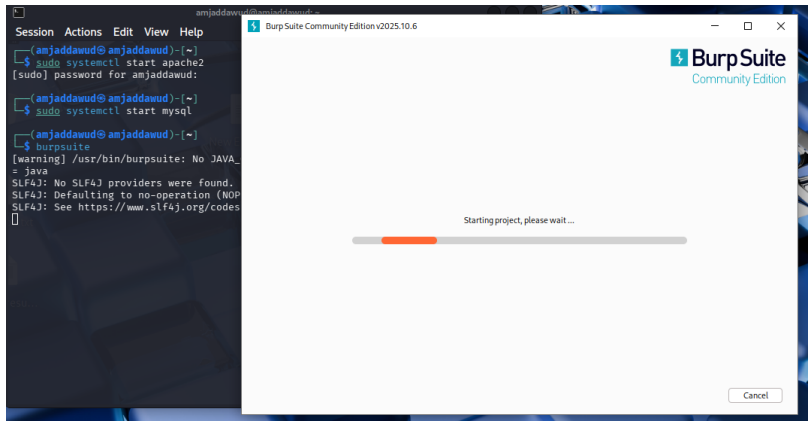


Рисунок 2: Запуск приложения

1.5 Выполнение лабораторной работы

Открываю сетевые настройки браузера, для подготовке к работе

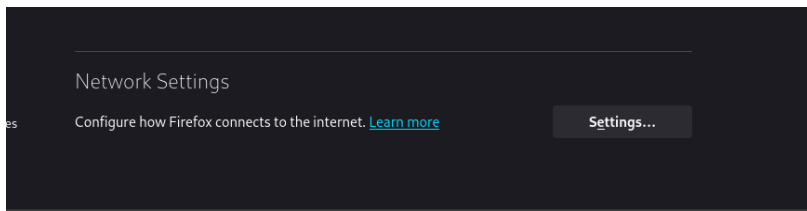
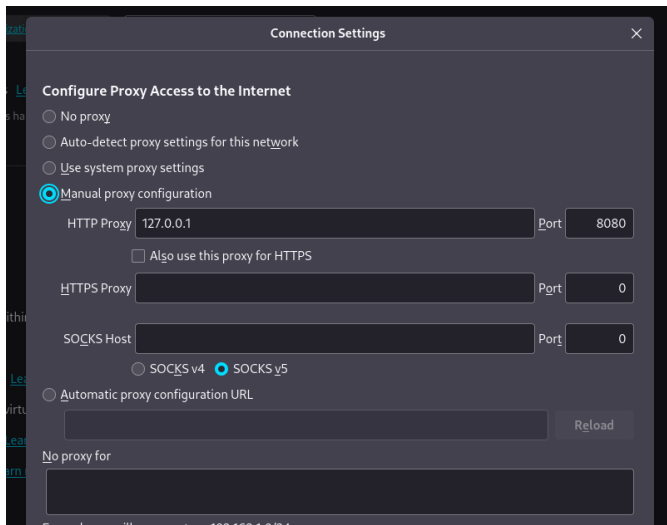


Рисунок 3: Сетевые настройки браузера

1.6 Выполнение лабораторной работы

Изменение настроек сервера для работы с прокси и захватом данных с помощью Burp Suite



Изменяю настройки Proxy инструмента Burp Suite для дальнейшей работы



1.8 Выполнение лабораторной работы

Во вкладке Proxy устанавливаю «Intercept is on»

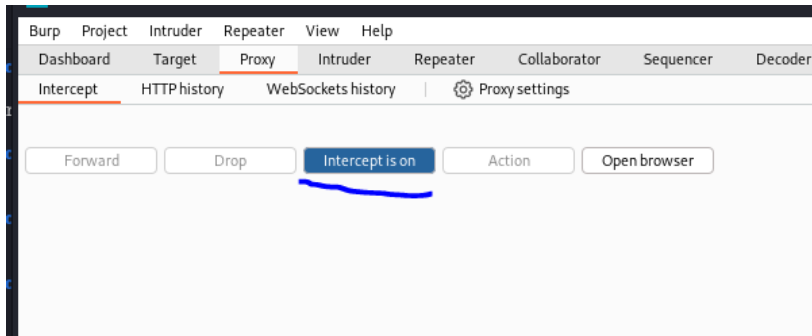


Рисунок 6: Настройки Proxy

1.9 Выполнение лабораторной работы

Чтобы Burp Suite исправно работал с локальным сервером, необходимо установить параметр `network.allow_hijacking_localhost` на `true`

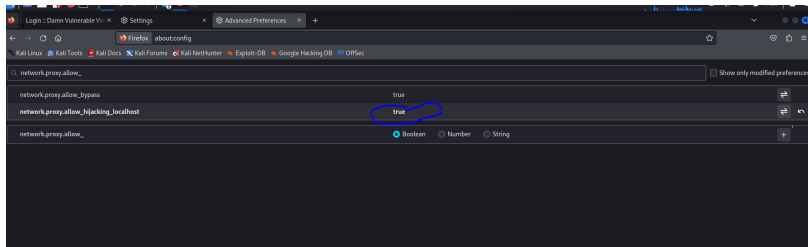


Рисунок 7: Настройки параметров

1.10 Выполнение лабораторной работы

Пытаюсь зайти в браузере на DVWA, тут же во вкладки Proxu появляется захваченный запрос. Нажимаем «Forward», чтобы загрузить страницу

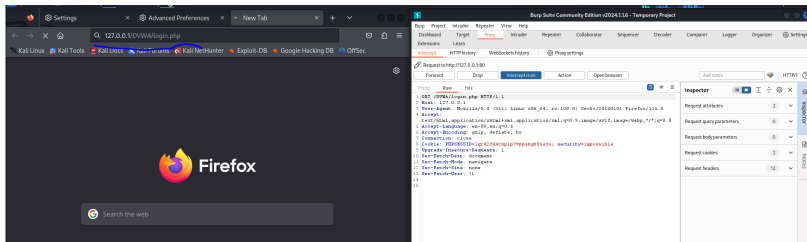


Рисунок 8: Получаемые запросы сервера

1.11 Выполнение лабораторной работы

Загрузилась страница авторизации, текст запроса поменялся

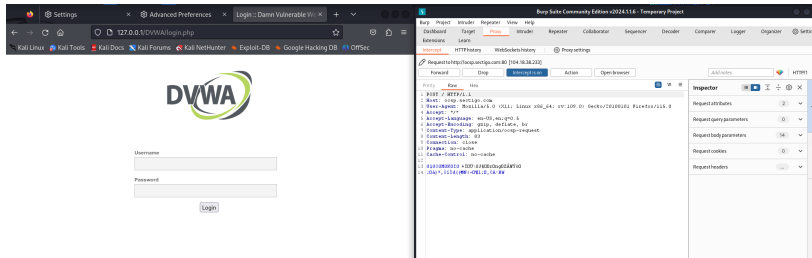


Рисунок 9: Страница авторизации

1.12 Выполнение лабораторной работы

История запросов хранится во вкладке Target

The screenshot shows the Burp Suite Community Edition v2024.11.6 interface. The 'Target' tab is selected in the top menu. The left sidebar shows a tree view with 'http://127.0.0.1' selected. The main panel displays a table of requests and responses.

Host	Method	URL	Params	Status Code	Length	MIME type	Title
http://127.0.0.1	GET	/DVWA/login.php		200	1633	HTML	Login :: Damn Vulnera...
http://127.0.0.1	GET	/DVWA/dvwa/images...					

Below the table, the 'Request' and 'Response' tabs are visible. The 'Request' tab is selected, showing the raw request details:

```
1 GET /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: close
8 Cookie: PHPSESSID=lgrdCfd4cuplp7vppsbgk8saju; security=impossible
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
```

The right sidebar shows the 'Inspector' tab with a list of request attributes:

- Request attributes: 2
- Request cookies: 2
- Request headers: 12
- Response headers: 9

1.13 Выполнение лабораторной работы

Попробуем ввести неправильные, случайные данные в веб-приложении и нажмем Login. В запросе увидим строку, в которой отображаются введенные нами данные, то есть поле для ввода

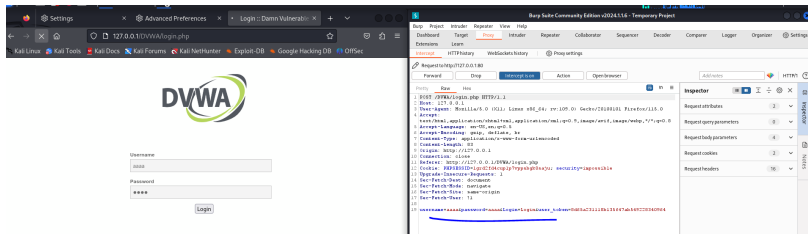
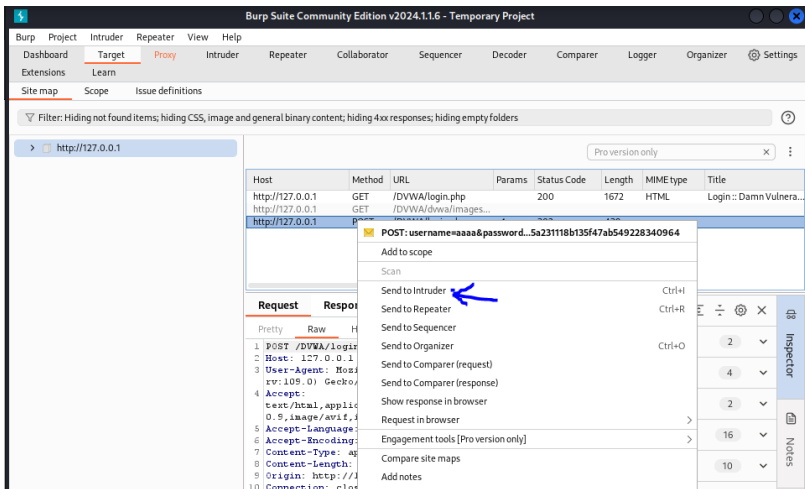


Рисунок 11: Ввод случайных данных

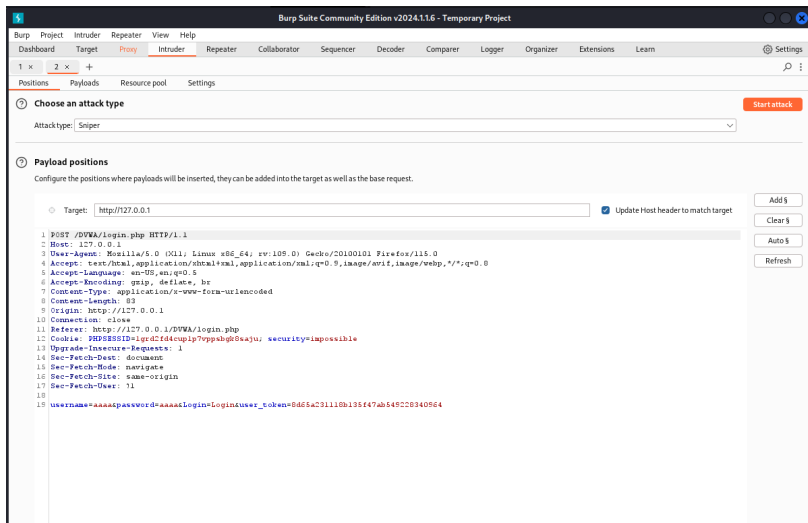
1.14 Выполнение лабораторной работы

Этот запрос так же можно найти во вкладке Target, там же жмем правой кнопкой мыши на хост нужного запроса, и далее нажимаем «Send to Intruder»



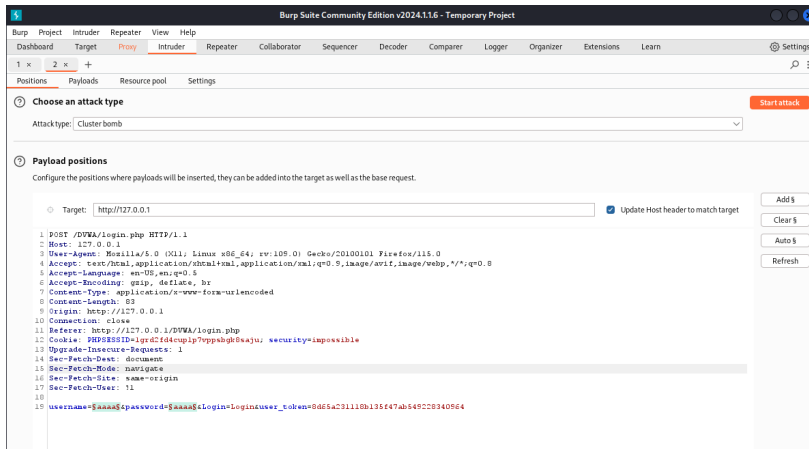
1.15 Выполнение лабораторной работы

Попадаем на вкладку Intruder, видим значения по умолчанию у типа атаки и наш запрос



1.16 Выполнение лабораторной работы

Изменяем значение типа атаки на Cluster bomb и проставляем специальные символы у тех данных в форме для ввода, которые будем пробивать, то есть у имени пользователя и пароля



1.17 Выполнение лабораторной работы

Так как мы отметили два параметра для подбора, то нам нужно два списка со значениями для подбора. Заполняем первый список в **Payload setting**

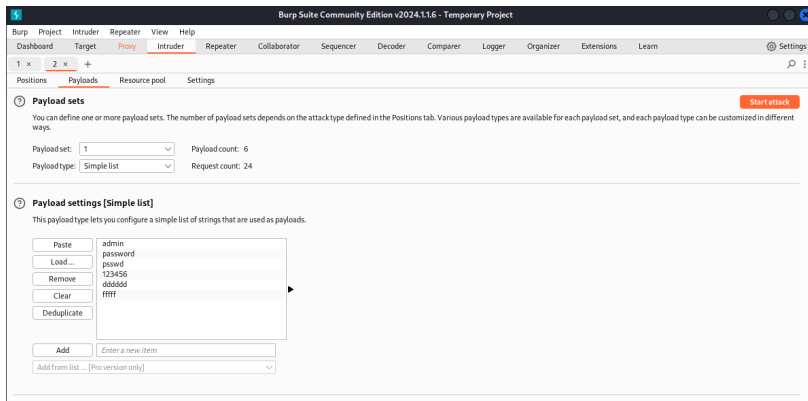


Рисунок 15: Первый Simple list

1.18 Выполнение лабораторной работы

Переключаемся на второй список и добавляем значения в него. В строке request count видим нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль

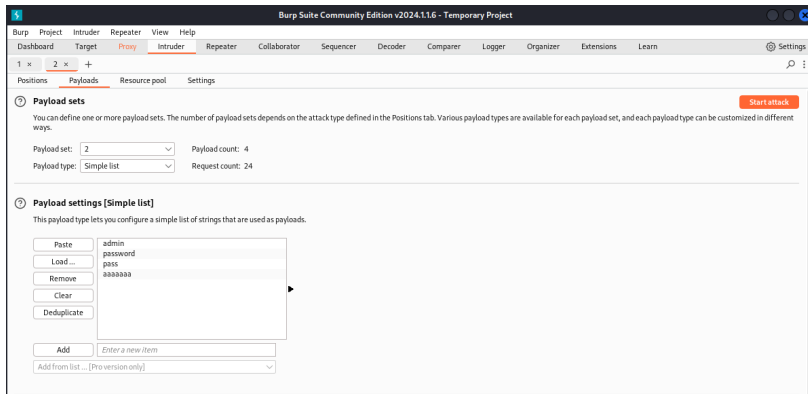
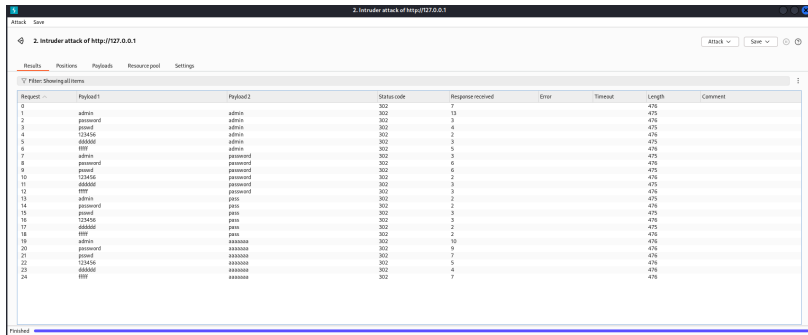


Рисунок 16: Второй Simple list

1.19 Выполнение лабораторной работы

Запускаю атаку и начинаю подбор



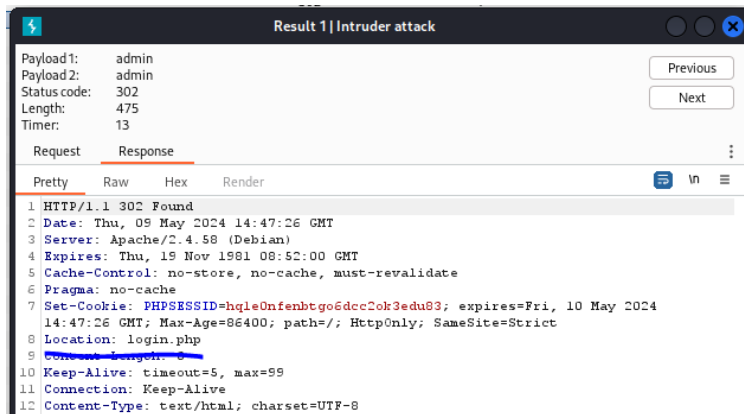
The screenshot shows the Burp Suite interface with the 'Results' tab selected. The title bar indicates '2. Intruder attack of http://127.0.0.1'. The table below lists the results of the attack, showing request numbers, payloads, status codes, and response lengths.

Request	Payload1	Payload2	Status code	Response received	Error	Timeout	Length	Comment
0			302	7			476	
1	admin	admin	302	13			476	
2	password	admin	302	3			476	
3	passwd	admin	302	4			476	
4	123456	admin	302	2			476	
5	aaaaaa	admin	302	3			476	
6	ffff	admin	302	5			476	
7	admin	password	302	3			476	
8	password	password	302	6			476	
9	passwd	password	302	6			476	
10	123456	password	302	2			476	
11	aaaaaa	password	302	3			476	
12	ffff	password	302	3			476	
13	admin	pass	302	2			476	
14	password	pass	302	2			476	
15	passwd	pass	302	3			476	
16	123456	pass	302	3			476	
17	aaaaaa	pass	302	2			476	
18	ffff	pass	302	2			476	
19	admin	aaaaaaa	302	10			476	
20	password	aaaaaaa	302	9			476	
21	passwd	aaaaaaa	302	7			476	
22	123456	aaaaaaa	302	5			476	
23	aaaaaa	aaaaaaa	302	4			476	
24	ffff	aaaaaaa	302	7			476	

Рисунок 17: Запуск атаки

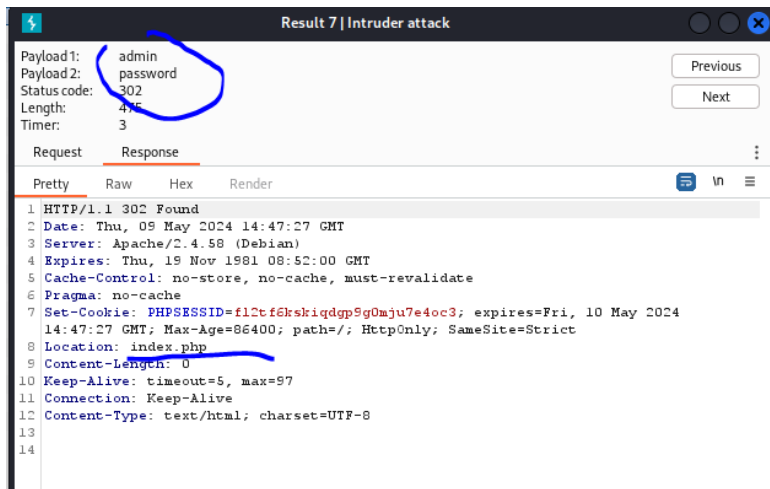
1.20 Выполнение лабораторной работы

При открытии результата каждого post-запроса можно увидеть полученный get-запрос, в нем видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. В представленном случае с подбором пары admin-admin нас перенаправило на login.php, это значит, что пара не подходит



1.21 Выполнение лабораторной работы

Проверим результат пары admin-password во вкладке Response, теперь нас перенаправляет на страницу index.php, значит пара должна быть верной



1.22 Выполнение лабораторной работы

Дополнительная проверка с использованием Repeater, нажимаем на нужный нам запрос правой кнопкой мыши и жмем «Send to Repeater»

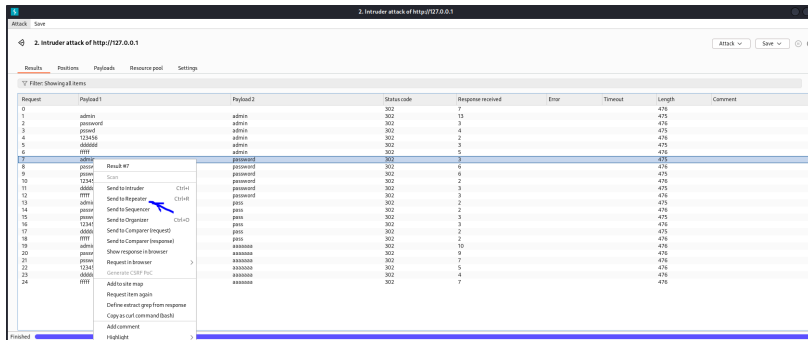
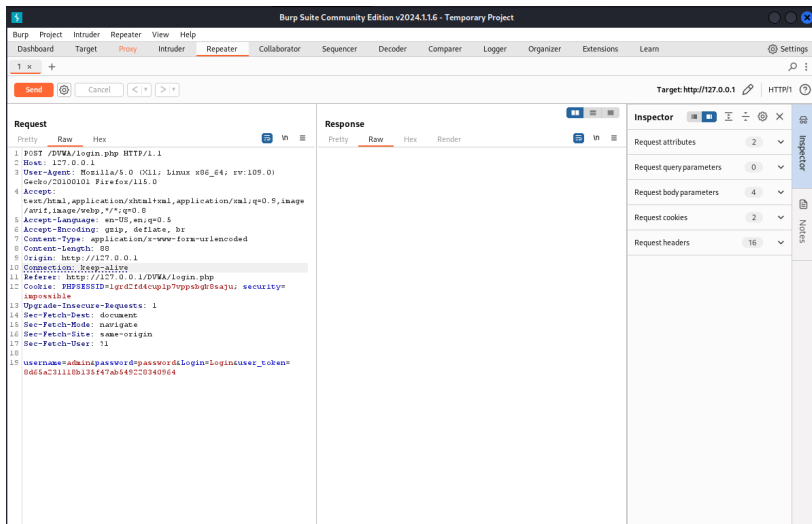


Рисунок 20: Дополнительная проверка результата

1.23 Выполнение лабораторной работы

Переходим во вкладку «Repeater»



1.24 Выполнение лабораторной работы

Нажимаем «send», получаем в Response в результат перенаправление на index.php

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The 'Target' is set to 'http://127.0.0.1'. The 'Request' pane shows an HTTP POST request to '/DVWA/login.php'. The 'Response' pane shows an HTTP 302 Found status with a 'Location' header set to 'index.php'. The 'Inspector' pane on the right shows the 'Request attributes' and 'Request headers'.

Request

```
1 POST /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0)
  Gecko/20100101 Firefox/115.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image
  /svg,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 88
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DVWA/login.php
12 Cookie: PHPSESSID=1grd2fd4cuplp7vppsbgk8saJu; security=
  impossible
13 Upgrade-Insecure-Requests: 1
14 Sec-Fetch-Dest: document
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-Site: same-origin
17 Sec-Fetch-User: 11
18
19 username=admin&password=password&login=Login&user_token=
  8d65a23110b135f47ab549228340964
```

Response

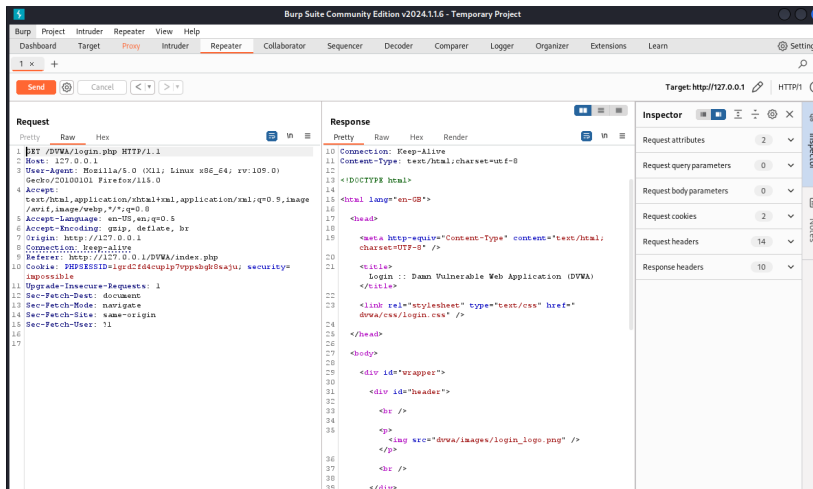
```
1 HTTP/1.1 302 Found
2 Date: Thu, 09 May 2024 14:51:42 GMT
3 Server: Apache/2.4.58 (Debian)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Set-Cookie: PHPSESSID=dv7q7lumsiu7vb7wc7b886c95;
  expires=Fri, 10 May 2024 14:51:42 GMT; Max-Age=86400;
  path=/; HttpOnly; SameSite=Strict
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 4
- Request cookies: 2
- Request headers: 16
- Response headers: 11

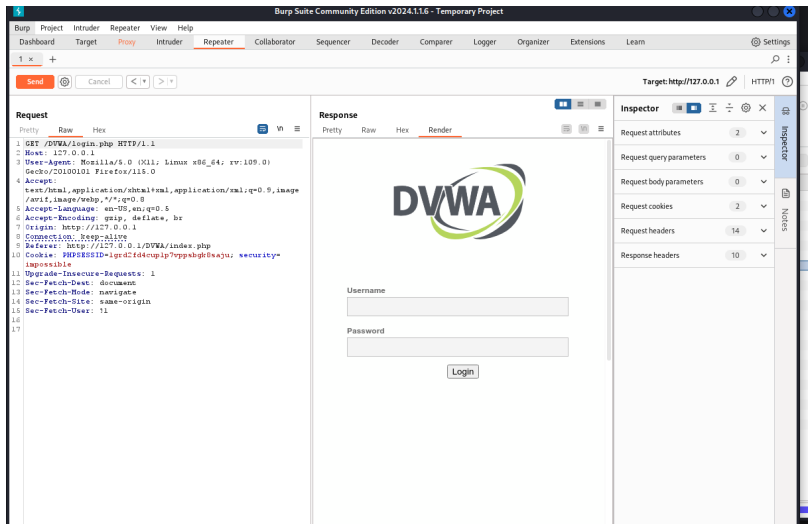
1.25 Выполнение лабораторной работы

После нажатия на Follow redirection, получим неcompiled html код в окне Response



1.26 Выполнение лабораторной работы

Далее в подокне Render получим то, как выглядит полученная страница



При выполнении лабораторной работы научилась использовать инструмент Burp Suite.
...